



UNIVERSIDAD SAN FRANCISCO

Reporte sobre This Is How They Tell Me the World Ends de Nicole Perlroth

Integrantes: Giselle Cevallos, Emilio Soria, Esteban Silva

Seguridad informática

5/5/2026

Resumen

Este informe analiza *This Is How They Tell Me the World Ends* como una historia técnica, política y moral de la industria de las ciberarmas. La fuente única del trabajo es el libro de Nicole Perlroth; por esa razón, los casos, personajes y ejemplos se presentan como aparecen en la obra, sin añadir fuentes externas. El objetivo no es resumir todos los capítulos, sino usar el libro para explicar cómo una vulnerabilidad desconocida puede convertirse en mercancía, arma estatal, herramienta de vigilancia privada y riesgo masivo para usuarios comunes.

La tesis central de este reporte es que Perlroth muestra un cambio decisivo en la seguridad informática: el conocimiento técnico dejó de pertenecer solo a comunidades de investigación o a empresas que buscaban corregir fallas, y pasó a circular en un mercado de alto valor donde gobiernos, contratistas, brokers y empresas de spyware compiten por acceso. Esa competencia aumenta la capacidad ofensiva de los Estados, pero también multiplica el riesgo sistémico. Cuando las fallas se guardan, se venden o se pierden, la población civil queda expuesta a las mismas herramientas que originalmente se justificaron como defensa nacional.

El informe se divide en cuatro partes. Primero, se presenta un desglose técnico de tres tecnologías o familias de tecnologías descritas en el libro: los zero-days y las cadenas de exploits; los sistemas de control industrial usados como blanco en Stuxnet; y el protocolo SMB explotado por EternalBlue y reutilizado en ataques como WannaCry y NotPetya. Segundo, se analiza el impacto social: cambios en política pública, percepción ciudadana y comportamiento corporativo. Tercero, se ofrece una crítica personal desde la perspectiva de un futuro profesional de InfoSec. Finalmente, se incluye una rúbrica confidencial de evaluación entre pares para la entrega en D2L.

La conclusión general es que el libro desplaza la pregunta de “¿quién puede hackear?” hacia una pregunta más difícil: “¿qué obligaciones tiene quien descubre, compra, vende o guarda una falla que afecta a millones de personas?”. En ese desplazamiento está la importancia ética del texto para cualquier estudiante de ciberseguridad.

Introducción

Perlroth no presenta la ciberseguridad como una sucesión aislada de incidentes técnicos. La estructura del libro muestra una progresión histórica: primero aparecen hackers curiosos y empresas que no quieren admitir fallas; después surgen intermediarios que pagan por vulnerabilidades; más tarde entran agencias de inteligencia, contratistas militares y

compañías privadas capaces de convertir fallas en productos de espionaje. Lo inquietante es que esta evolución no ocurre en un mundo separado del usuario común. Las mismas computadoras, teléfonos, routers, servidores y protocolos que usa una agencia de inteligencia también sostienen bancos, hospitales, elecciones, fábricas, cadenas de suministro y hogares.

El concepto que organiza gran parte del libro es el zero-day. En términos sencillos, un zero-day es una falla para la cual aún no existe parche público. La empresa que fabrica el software o hardware no ha tenido tiempo de corregirla porque ni siquiera sabe, o no ha reconocido, que existe. Esa condición de invisibilidad le da valor. Mientras la falla permanezca secreta, un atacante puede usarla contra sistemas completamente actualizados, porque no hay una defensa específica disponible. En la lógica de mercado que describe Perlroth, esa invisibilidad se monetiza: puede venderse al fabricante para que la corrija, a un programa de recompensas, a un broker, a una agencia estatal o a una empresa de spyware.

La obra también insiste en el carácter dual de la investigación. La misma habilidad que permite encontrar una falla antes que los criminales puede convertirse en una herramienta para espiar, sabotear o perseguir disidentes. Por eso el libro resulta especialmente relevante para estudiantes de seguridad informática: no basta con saber explotar una vulnerabilidad; hay que decidir qué se hace con ese conocimiento, a quién se entrega, en qué condiciones y con qué responsabilidad frente a los usuarios afectados.

1. Technical Breakdown

1.1 Zero-days, exploits y cadenas de explotación

La primera tecnología central del libro no es un producto específico, sino una categoría de conocimiento técnico: el zero-day. Perlroth lo define como una falla de software o hardware sin parche disponible. Su valor no está únicamente en descubrir que la falla existe, sino en convertirla en un exploit confiable. Una vulnerabilidad puede causar un bloqueo o un comportamiento extraño; un exploit funcional, en cambio, permite ejecutar una acción concreta: entrar al sistema, elevar privilegios, instalar una puerta trasera, extraer datos o moverse lateralmente.

El libro ayuda a distinguir entre “bug”, “vulnerabilidad” y “arma”. Un bug puede ser un error de programación. Se vuelve vulnerabilidad cuando ese error afecta la seguridad. Se vuelve arma cuando alguien desarrolla código para explotarlo de manera repetible y lo integra a una operación. En ese punto aparecen conceptos como persistencia, evasión y exfiltración. Persistencia significa mantener acceso incluso si el sistema se reinicia o si el usuario cambia algunas configuraciones. Evasión significa evitar antivirus, herramientas de monitoreo o detección de intrusos. Exfiltración significa extraer datos hacia un servidor controlado por el atacante sin levantar sospechas.

Perlroth describe que las operaciones más valiosas rara vez dependen de un solo error. Con frecuencia se encadenan varios exploits. Un exploit puede servir para abrir la puerta inicial, otro para escalar privilegios, otro para escapar de un sandbox y otro para instalar una carga útil. Esta idea aparece de forma clara en los relatos sobre teléfonos inteligentes: comprometer un iPhone o un Android moderno no suele ser cuestión de un único fallo, sino de una cadena que atraviesa varias capas de defensa. La cadena completa vale más porque reduce la interacción del usuario y aumenta la confiabilidad de la intrusión.

El problema ético nace de la asimetría de información. El usuario cree que su sistema está seguro porque está actualizado, pero el atacante conoce un camino que el fabricante y el público desconocen. Si el investigador reporta la falla al fabricante, el valor ofensivo cae, pero aumenta la seguridad colectiva. Si la vende a un broker o a una agencia que exige silencio, el valor económico puede ser mayor, pero el riesgo permanece abierto para todos los usuarios que dependen del sistema. Esa tensión atraviesa historias como iDefense, Charlie Miller, VUPEN, Zerodium y NSO Group.

En términos técnicos, el zero-day también cuestiona la confianza en la defensa tradicional. Un antivirus puede detectar firmas conocidas; un firewall puede bloquear tráfico

esperado; una política de parches puede cerrar fallas ya identificadas. Sin embargo, un zero-day bien diseñado funciona precisamente porque se aprovecha de algo que todavía no está en las reglas defensivas. Por eso Perlroth muestra que la seguridad moderna no puede reducirse a instalar parches: también requiere monitoreo de comportamiento, segmentación, reducción de superficie de ataque, respuesta a incidentes y una política responsable de divulgación.

1.2 Sistemas de control industrial, Stuxnet y el salto de lo digital a lo físico

La segunda tecnología importante es la de los sistemas de control industrial. En el libro, estos sistemas aparecen vinculados a plantas eléctricas, instalaciones nucleares, fábricas, oleoductos, refinerías y otros entornos donde el software controla procesos físicos. A diferencia de una computadora personal, un sistema de control industrial no solo almacena o procesa información: puede abrir válvulas, modificar presión, apagar energía, cambiar velocidades de motores o alterar el funcionamiento de una máquina.

Stuxnet es el ejemplo más claro del cruce entre ciberataque y daño físico. Según la narración de Perlroth, el gusano fue diseñado para llegar a sistemas altamente protegidos, incluso desconectados de internet, y para afectar centrifugadoras usadas en el programa nuclear iraní. Técnicamente, Stuxnet combinó múltiples zero-days, mecanismos de propagación y conocimiento específico de software industrial. No buscaba robar contraseñas de forma general; buscaba manipular un proceso físico concreto mientras ocultaba a los operadores lo que estaba ocurriendo.

El punto técnico más relevante es que Stuxnet no atacaba solo “computadoras”, sino la relación entre computadoras y máquinas. En entornos industriales, los controladores lógicos programables reciben instrucciones y ejecutan acciones sobre equipos físicos. Si un atacante modifica esas instrucciones, puede provocar que el equipo trabaje fuera de sus parámetros seguros. En el caso narrado por Perlroth, la manipulación de centrifugadoras demuestra que la frontera entre software y mundo material es artificial: cuando el software controla infraestructura, vulnerar el software puede significar alterar la realidad física.

También es importante la dimensión de propagación. Los sistemas sensibles suelen aislarse o limitarse mediante redes separadas, pero el libro muestra que el aislamiento no es absoluto. Un USB, una actualización, un proveedor o un operador pueden convertirse en puente. Esto convierte la cadena de suministro y el comportamiento humano en parte del perímetro técnico. El atacante no necesita entrar por la puerta principal si puede comprometer un eslabón secundario y esperar que el código llegue al entorno objetivo.

Stuxnet cambió el imaginario de la ciberseguridad porque probó que una operación digital podía generar efectos físicos estratégicos. También mostró un precedente peligroso: una herramienta creada para un objetivo específico puede escapar, ser estudiada, copiada o inspirar a otros actores. En el libro, esa consecuencia pesa más que la eficacia inmediata. La innovación ofensiva de un Estado no queda encerrada para siempre en el Estado que la creó; una vez revelada, se vuelve parte del repertorio global de ataque.

1.3 SMB, EternalBlue, WannaCry y NotPetya

La tercera tecnología específica es el protocolo SMB de Windows, asociado en el libro con EternalBlue. SMB permite compartir archivos, impresoras y otros recursos en redes Windows. Precisamente por ser común en entornos corporativos, un fallo grave en SMB tiene un potencial de propagación enorme. Si una organización tiene muchos equipos Windows conectados entre sí, un exploit contra SMB puede servir como mecanismo de movimiento lateral: un equipo comprometido permite alcanzar otros sin necesidad de que cada usuario abra un archivo malicioso.

EternalBlue aparece como una herramienta desarrollada o guardada por la NSA y luego filtrada por Shadow Brokers. El aspecto técnico fundamental es que no se trataba solo de una vulnerabilidad conocida por criminales comunes; era una capacidad ofensiva sofisticada, retenida durante años y finalmente publicada de forma que cualquier actor pudiera reutilizarla. Una vez fuera de control, el exploit fue integrado en ataques de alcance global. WannaCry lo usó con lógica de ransomware; NotPetya lo incorporó en una operación destructiva disfrazada de ransomware.

La diferencia entre ransomware y wiper es esencial. En un ransomware real, la atacante cifra archivos y exige pago con la promesa de descifrarlos. En un wiper, la finalidad es destruir, inutilizar o borrar información, aunque se disfraza de extorsión. Perlroth subraya que NotPetya se presentó como ransomware, pero no ofrecía una vía realista de recuperación. Su objetivo era dañar. Al aprovechar herramientas filtradas y mecanismos de propagación en redes, el ataque salió de Ucrania y afectó compañías globales, logística, farmacéuticas, servicios postales, estaciones, cajeros y sistemas de monitoreo.

Desde una perspectiva defensiva, EternalBlue enseña varias lecciones. Primero, los parches son urgentes, pero no siempre suficientes: muchas organizaciones tienen sistemas antiguos, ventanas de mantenimiento limitadas o dependencia de equipos que no pueden reiniciarse fácilmente. Segundo, la segmentación de red es crítica: si todos los equipos confían entre sí, el atacante avanza más rápido. Tercero, las herramientas ofensivas estatales

no desaparecen por estar clasificadas; si se filtran, el daño se democratiza. Cuarto, la responsabilidad no puede colocarse solo en el administrador que no parcheó, porque la decisión inicial de guardar la vulnerabilidad creó una exposición colectiva.

2. Impacto Social

2.1 Cambios en política pública y regulación

El impacto social más visible del libro es la presión sobre los gobiernos para explicar qué hacen con las vulnerabilidades que descubren o compran. La idea de que una agencia pueda retener fallas en productos usados por millones de personas genera una pregunta política: ¿cuándo debe el Estado guardar una vulnerabilidad para inteligencia y cuándo debe revelarla para proteger a la población? Perlroth presenta esta tensión a través del debate sobre el Vulnerabilities Equities Process, un procedimiento destinado a decidir si el gobierno estadounidense conserva o divulga un zero-day.

La existencia de ese proceso no elimina el problema, pero sí muestra que el tema salió de la sombra absoluta. Eventos como Heartbleed, Snowden, Shadow Brokers, WannaCry y NotPetya forzaron a autoridades a reconocer que la acumulación de vulnerabilidades no es solo una cuestión militar. Cuando una falla afecta protocolos, bibliotecas o sistemas usados por hospitales, empresas, gobiernos locales y ciudadanos, la decisión de callar tiene consecuencias civiles. Por eso el criterio de “seguridad nacional” ya no puede entenderse únicamente como ventaja ofensiva; también debe incluir resiliencia social, infraestructura crítica y protección de usuarios.

El libro también muestra presión regulatoria sobre la industria privada de spyware. Empresas como Hacking Team, VUPEN, Zerodium y NSO Group operan en un espacio donde las herramientas pueden presentarse como apoyo a la seguridad pública o lucha contra el crimen, pero también pueden usarse contra periodistas, disidentes y opositores. Cuando las filtraciones y reportajes revelan abusos, los reguladores comienzan a mirar exportaciones, licencias y controles. La lección es que el comercio de exploits se parece cada vez más al comercio de armas: no basta con decir que el cliente es un gobierno; importa cómo ese gobierno usa la herramienta y contra quién.

2.2 Cambios en la percepción pública

La percepción pública de la ciberseguridad cambia porque los ataques dejan de verse como molestias digitales. En el prólogo, Ucrania funciona como advertencia: apagones, estaciones de gasolina, cajeros, trenes, servicios postales y sistemas de monitoreo pueden

verse afectados por operaciones digitales. Esto transforma el ciberataque en experiencia cotidiana. Ya no es solo una contraseña robada, sino el no poder cobrar, transportarse, registrar compras, enviar paquetes o saber si una instalación crítica funciona correctamente.

Snowden también altera la percepción pública, pero de otra manera: instala un déficit de confianza. Perlroth muestra que, después de las revelaciones sobre vigilancia, las empresas tecnológicas y muchos usuarios desconfían de mecanismos de intercambio de información con el gobierno. Incluso cuando se habla de compartir indicadores de amenazas o datos de vulnerabilidades, el temor es que los clientes internacionales lo interpreten como una puerta trasera. La seguridad pública queda atrapada en una paradoja: se necesita cooperación, pero la historia de vigilancia secreta hace que la cooperación sea sospechosa.

El libro también transforma la imagen del hacker. Al inicio, el hacker puede ser visto como investigador, curioso o rebelde técnico. Con el tiempo, aparece como proveedor de acceso en una cadena económica. Algunos siguen actuando como investigadores defensivos; otros venden a brokers; otros trabajan para agencias o empresas de mercenarios digitales. La percepción pública se vuelve más ambivalente: el hacker ya no es simplemente criminal ni héroe, sino una figura con poder real, cuyas decisiones pueden proteger o poner en riesgo a millones.

2.3 Cambios en comportamiento corporativo

Las empresas tecnológicas también cambian. Microsoft es uno de los casos más importantes. El libro muestra que, después de años de críticas y ataques asociados a sus productos, la compañía se vio obligada a tomar la seguridad como prioridad. Iniciativas como Trustworthy Computing, el ciclo regular de parches y una relación más estructurada con investigadores reflejan un giro corporativo: la seguridad deja de ser un añadido y se vuelve parte del diseño, la reputación y la supervivencia comercial.

Otro cambio es el crecimiento de programas de bug bounty y recompensas por divulgación responsable. Si los brokers pagan por silencio, las empresas necesitan pagar por reparación. El incentivo importa. Un investigador que encuentra una falla crítica debe tener una vía clara, legal y respetuosa para reportarla. Si la respuesta corporativa es amenaza legal, indiferencia o demora, el mercado gris se vuelve más atractivo. Perlroth muestra que la hostilidad inicial de algunas empresas hacia hackers ayudó a empujar talento hacia compradores ofensivos. En cambio, las recompensas, el puerto seguro legal y la comunicación profesional pueden atraer ese conocimiento hacia la defensa.

La conducta corporativa también cambia en torno al software de código abierto. El libro utiliza Heartbleed para mostrar que componentes invisibles y mantenidos por pocas personas sostienen gran parte de la economía digital. Después de crisis así, empresas y fundaciones comienzan a financiar auditorías, censos de dependencias y mantenimiento de proyectos críticos. Esto demuestra que la seguridad no solo depende de grandes productos comerciales, sino de bibliotecas pequeñas, protocolos abiertos y voluntarios que necesitan recursos reales.

Finalmente, compañías como Apple, Google, Microsoft y otras se vuelven más agresivas en cifrado, parches, endurecimiento de plataformas y transparencia frente a solicitudes gubernamentales. No actúan solo por altruismo; también defienden confianza de mercado. Si los clientes creen que un producto es canal de espionaje estatal, el daño reputacional es enorme. Así, la ciberseguridad se convierte en una forma de legitimidad corporativa.

3. Crítica del equipo

Como futuros profesionales de seguridad informática, el libro cambia nuestra manera de entender la responsabilidad técnica. Antes de leer una obra como esta, es fácil pensar que la ética se limita a no atacar sistemas ajenos sin permiso. Perlroth nos obliga a ir más allá. La pregunta ética no empieza cuando se ejecuta un exploit; empieza cuando se descubre una falla y se decide qué hacer con ella. Esa decisión puede cerrar una puerta para todos o mantenerla abierta para un grupo selecto de compradores. En seguridad, el silencio también es una acción.

Nuestra primera conclusión es que la habilidad técnica no neutraliza la responsabilidad. Encontrar un zero-day demuestra capacidad, pero no justifica automáticamente venderlo a quien pague más. El mercado descrito por Perlroth premia la exclusividad y la opacidad, justo los dos elementos que más riesgo crean para el público. Si una vulnerabilidad afecta teléfonos, navegadores, sistemas operativos o infraestructura, un profesional no puede imaginarse como dueño absoluto de ese conocimiento. Hay usuarios reales detrás: periodistas, pacientes, empresas pequeñas, estudiantes, familias y comunidades enteras.

Nuestra segunda conclusión es que la defensa debe tener prioridad moral sobre la curiosidad ofensiva. Aprender explotación es necesario para comprender cómo atacan los adversarios, pero la finalidad importa. En un laboratorio controlado, explotar un sistema

puede ser aprendizaje. En el mundo real, el mismo conocimiento puede alimentar vigilancia contra disidentes o ataques destructivos. El libro nos lleva a separar claramente investigación, demostración responsable y comercialización opaca. La frontera no siempre será simple, pero debe discutirse antes de aceptar un proyecto, no después de que el daño ocurra.

La tercera conclusión se relaciona con el trabajo en empresas. Los profesionales de seguridad no solo deben reportar hallazgos; deben ayudar a crear procesos que hagan posible la reparación. Si una organización castiga a quien reporta fallas, la organización empuja el problema hacia el mercado gris. Por eso consideramos que una práctica ética incluye canales de divulgación, tiempos razonables de respuesta, protección legal para investigadores de buena fe, documentación clara y comunicación honesta con usuarios afectados. La ética no debe depender únicamente de individuos heroicos; debe estar incorporada en procesos.

La cuarta conclusión es que la seguridad nacional no puede usarse como excusa total. Se entiende que los Estados necesitan inteligencia y que algunas capacidades ofensivas pueden prevenir amenazas reales. Sin embargo, Perlroth muestra que guardar vulnerabilidades crea una deuda de riesgo. Si la herramienta se filtra, si un adversario descubre la misma falla o si el exploit se reutiliza, el daño cae sobre civiles. Como futuros profesionales, eso nos lleva a desconfiar de argumentos que presentan la acumulación de zero-days como protección automática. La pregunta correcta debería ser: ¿a quién vuelve más segura esta decisión y a quién deja expuesto?

Finalmente, el libro nos hace pensar la ética como una práctica de humildad. Ningún equipo controla por completo el ciclo de vida de una herramienta ofensiva. Stuxnet escapó de su objetivo, Shadow Brokers filtró herramientas altamente sensibles y NotPetya se expandió más allá de Ucrania. La historia que cuenta Perlroth repite una misma advertencia: en sistemas complejos, las consecuencias no obedecen siempre al plan original. Por eso una ética madura en InfoSec debe asumir límites, incertidumbre y daño colateral. No basta con decir “nosotros solo hicimos nuestra parte”.

Después del libro, nuestro compromiso sería trabajar bajo tres principios. Primero, preferir divulgación responsable y mitigación antes que lucro por silencio. Segundo, evaluar el impacto humano de cualquier herramienta, incluso cuando parezca técnicamente elegante. Tercero, defender una cultura en la que la seguridad se mida por la reducción de riesgo colectivo, no por la acumulación secreta de acceso. Si la ciberseguridad protege solo a quien puede pagar por armas digitales, entonces ha fallado como disciplina pública.

Conclusión

This Is How They Tell Me the World Ends es relevante porque convierte un tema técnico en una discusión sobre poder. Los zero-days, los exploits contra sistemas industriales, el abuso de SMB mediante EternalBlue y la expansión de spyware comercial no son fenómenos aislados. Todos expresan una misma lógica: el acceso secreto tiene valor económico y geopolítico. El problema es que ese valor privado o estatal suele construirse sobre la inseguridad pública.

El desglose técnico muestra que una vulnerabilidad no es peligrosa solo por existir, sino por la cadena de decisiones que la rodea: descubrirla, callarla, venderla, guardarla, filtrarla o corregirla. El impacto social demuestra que esas decisiones han cambiado leyes, procesos de divulgación, programas de recompensas, exportaciones, confianza ciudadana y estrategias corporativas. La crítica del equipo concluye que futuros profesionales de seguridad informática deben pensar menos como mercenarios del acceso y más como custodios de sistemas de los que dependen personas reales.

La lección final del libro no es abandonar la investigación ofensiva, sino someterla a responsabilidad. Entender cómo se rompen los sistemas es indispensable para defenderlos. Pero cuando la explotación se separa de la reparación y del interés público, la seguridad se convierte en una carrera armamentista que nadie controla del todo. En ese sentido, la obra de Perlroth funciona como advertencia para estudiantes: cada habilidad técnica que adquirimos también crea una obligación ética.

4. Rúbrica de evaluación entre pares

Criterio	Descripción	Puntaje (1-5)
Lectura y aportes	Leyó los capítulos asignados y aportó ideas propias, ejemplos o conexiones relevantes del libro.	
Cumplimiento de plazos	Entregó borradores, revisiones o secciones internas dentro de los tiempos acordados por el equipo.	
Análisis técnico	Su explicación técnica fue precisa, clara y coherente con los eventos y tecnologías descritos en el libro.	
Colaboración	Ayudó a mejorar ideas de otros, revisó redacción, dio retroalimentación y no se limitó únicamente a “hacer su parte”.	
Responsabilidad final	Participó en la integración, edición, consistencia del informe y preparación de la entrega final.	

Evaluación individual de integrantes:

Integrante	Promedio
Giselle Cevallos	5
Esteban Silva	5

Referencias:

Perloth, N. (2021). *This is how they tell me the world ends: The cyber-weapons arms race*.
Bloomsbury Publishing.